

1. Protocoale de Autentificare

1. Authentication, Authorization, Accounting (AAA)

- **Autentificare** – Verificarea identității utilizatorului.
- **Autorizare** – Determinarea resurselor la care are acces un utilizator.
- **Accounting** – Urmărirea și înregistrarea acțiunilor utilizatorilor.

2. Factori de autentificare

- **Ceea ce utilizatorul cunoaște** – Parolă, PIN.
- **Ceea ce utilizatorul deține** – Certificat digital, token.
- **Ceea ce utilizatorul este** – Amprentă, voce (biometrie).
- **Autentificarea sigură presupune utilizarea a cel puțin doi factori** (autentificare multi-factor – MFA).

3. Tipuri de autentificare

- **Autentificare directă** – Fiecare sistem își gestionează propriile credențiale (potrivită pentru sisteme mici).
- **Autentificare indirectă** – Utilizarea unei baze de date centralizate (ex. RADIUS, TACACS+, LDAP), eficientă pentru management centralizat.

4. Protocoale de autentificare

- **PAP (Password Authentication Protocol)** – Transmite parola în clar (nesigur).
- **CHAP (Challenge-Handshake Authentication Protocol)** – Folosește un proces în trei pași (Challenge, Response, Success/Failure); parola nu circulă în clar.
- **NTLM (Windows NT LAN Manager)** – Autentificare pentru domenii Windows; dependent de un **Domain Controller (DC)**.
- **Kerberos** – Dezvoltat de MIT, bazat pe **Key Distribution Center (KDC)**, folosește criptografie simetrică și autentificare mutuală.

5. Kerberos – Funcționare și securitate

- **Utilizează tickete** – KDC emite un **Ticket-Granting Ticket (TGT)** pentru sesiuni de autentificare mai lungi (8-24 ore).
- **Replicare KDC** – Pentru redundanță, KDC Master transferă baza de date către KDC Slave.
- **Autentificarea între realm-uri** – Permite comunicarea securizată între domenii diferite.

6. Autentificare cu certificate digitale

- **Standard X.509** – Recomandare ITU-T pentru infrastructura de chei publice (PKI).

- **Autoritate de Certificare (CA)** – Garantează autenticitatea unei chei publice.
- **Autentificare bazată pe certificate X.509:**
 - **One-way authentication** – Clientul se autentifică la server.
 - **Two-way authentication** – Clientul și serverul se autentifică reciproc.
 - **Three-way authentication** – Previne atacurile prin reluare (replay attacks).

7. Generatoare de parole de unică folosință (OTP)

- Soluție pentru evitarea atacurilor asupra parolelor statice:
 - **RSA SecurID**
 - **VASCO DIGIPASS**
 - **Google Authenticator**

8. Metode biometrice

- Amprenta, iris, voce, geometria feței/mâinii, ADN.
- **Performanță biometrică:**
 - **False Acceptance Rate (FAR)** – Acceptarea greșită a unui impostor.
 - **False Rejection Rate (FRR)** – Respingerea greșită a unui utilizator valid.

9. Evaluarea metodelor de autentificare

- **Cerințe organizaționale** – Securitate, scalabilitate, interoperabilitate.
- **Costuri** – Achiziție, implementare, operare.
- **Cerințe utilizator** – Ușurință în utilizare, portabilitate.

2. Protocoale de Securitate la Nivel Rețea

1. Rețele Private Virtuale (VPN)

- VPN permite interconectarea componentelor unei rețele private printr-o rețea publică (ex. Internet).
- Utilizări:
 - Conectarea utilizatorilor remote.
 - Interconectarea sucursalelor și partenerilor de afaceri.

2. Tehnologii de Tunelare a Datelor

- **Tunelarea** → Încapsularea datelor pentru a asigura securitatea transmisiei.
- Tipuri:
 - **Nivel 2:** PPTP, L2TP.
 - **Nivel 3:** IPSec.
 - **Nivel 4:** SSL.

3. VPN Remote Access & Site-to-Site

- **Remote Access VPN:**
 - Permite utilizatorilor să se conecteze la LAN printr-un tunel securizat.
 - Costul depinde de conexiunea locală la Internet.
- **Site-to-Site VPN:**
 - Tunel între gateway-uri pentru conectarea sucursalelor/partenerilor.
 - Costul este similar cu cel al accesului la Internet.

4. Avantajele VPN

- **Flexibilitate:** conectarea noilor locații este simplă.
 - **Administrare ușoară:** elimină necesitatea legăturilor dedicate.
 - **Scalabilitate:** conectarea unei noi sucursale necesită doar acces la Internet.
 - **Conectivitate globală.**
-

IPSec (Internet Protocol Security)

- **Extinde IPv4** cu funcționalități de securitate la Nivel 3+.
- Protejează comunicațiile pentru protocoale superioare (TCP, UDP).
- Necesită modificări în stiva TCP/IP a clienților/gateway-urilor.

5. Arhitectura IPSec

- Definită prin mai multe RFC-uri, ex. RFC 4301, 4302, 4303, 4306.
- Probleme de interoperabilitate între diferite implementări.

6. Protocoale IPSec: AH și ESP

- **AH (Authentication Header)**
 - Asigură integritatea și autentificarea originii datelor.
 - **Protocol number:** 51.
 - **ESP (Encapsulating Security Payload)**
 - Asigură confidențialitatea și autentificarea originii datelor.
 - **Protocol number:** 50.
 - Pot fi utilizate independent sau împreună.
 - **Moduri de operare:**
 - **Transport:** protejează doar payload-ul pachetului IP.
 - **Tunel:** protejează întregul pachet IP (inclusiv antetul).
-

7. Security Association (SA)

- Contract între cele două capete ale tunelului IPSec, conține:
 - Parametri criptografici (algoritmi, chei).
 - Timp de viață.
- Identificat prin **SPI (Security Parameters Index)**.

8. Internet Key Exchange (IKE)

- Gestionează **Security Associations (SA)**.
 - **ISAKMP** → framework pentru managementul cheilor și SA.
 - **IKE**:
 - Stabilește parametrii criptografici (ex. algoritmi de criptare).
 - Autentificare: pre-shared keys sau certificate digitale.
 - Stabilirea cheii de sesiune: **Diffie-Hellman (DH)**.
 - Folosește **UDP port 500**.
-

9. Moduri de lucru IKE

- **Faza 1**: Negocierea unui **ISAKMP SA**.
 - **Mod principal** (6 mesaje) → protecția identității.
 - **Mod agresiv** (3 mesaje) → nu protejează identitatea.
- **Faza 2**: Negocierea unui **IPSec SA** + reînnoșare chei sesiune.
 - **Mod rapid** → schimb de 3 mesaje criptate.

Perfect Forward Secrecy (PFS)

- Cheile sesiunilor sunt independente → compromiterea unei sesiuni nu afectează următoarea.
-

10. Implementarea IPSec VPN

- **Algoritmi recomandați**:
 - **Criptare**: 3DES, AES.
 - **Integritate**: SHA-2.
- **Provocări**:
 - Fragmentarea pachetelor (scade performanța rețelei).
 - NAT → IPSec NAT Traversal (NAT-T) în UDP.
 - Configurare firewall: **AH (51), ESP (50), IKE (UDP 500), NAT-T (UDP 4500)**.
 - **L2TP/IPSec** → asignare adrese IP prin DHCP.
 - **Extensii de autentificare**: RADIUS, TACACS+, RSA SecurID.

11. Soluții IPSec VPN

- Cisco, Juniper, CheckPoint VPN-1, Microsoft.
- Linux: strongSwan/OpenSwan.
- BSD: KAME, Racoon IKE daemon

3. Protocoale de Securitate la Nivel Transport

1. Protocolul SSL (Secure Sockets Layer)

- Dezvoltat de Netscape pentru a securiza comunicațiile pe internet.
- Funcționează peste TCP și oferă comunicație securizată prin socket-uri.
- Aplicațiile trebuie modificate pentru a suporta SSL, dar stiva TCP/IP rămâne nemodificată.
- Evoluția versiunilor:
 - **SSL v3.0** (1996, Internet Draft)
 - **TLS v1.0** (RFC 2246)
 - **TLS v1.1** (RFC 4346)
 - **TLS v1.2** (RFC 5246)
 - **TLS v1.3** (RFC 8446)

2. Protocoale SSL

- **SSL Handshake Protocol** – negociază algoritmi criptografici, schimbă chei, autentifică serverul și opțional clientul.
- **SSL Record Protocol** – transferă date, le fragmentează, le comprimă, asigură autenticitatea și integritatea (MAC), le criptează.
- **SSL Change Cipher Spec Protocol** – indică sfârșitul fazei de handshake.
- **SSL Alert Protocol** – gestionează mesajele de eroare.

3. SSL Handshake Protocol (Negocierea Conexiunii)

- **Etape principale:**
 - **client_hello / server_hello** – negociere versiune, algoritmi criptografici, chei.
 - **server_certificate** – serverul trimite certificatul său digital X.509.
 - **key exchange** – schimbul de chei folosind RSA sau Diffie-Hellman.
 - **change_cipher_spec** – ambele părți finalizează handshake-ul și încep comunicarea criptată.
- **Mecanisme de schimb de chei:**
 - **RSA** – cheia secretă este criptată cu cheia publică a serverului.
 - **Fixed Diffie-Hellman** – parametrii DH sunt incluși într-un certificat digital.
 - **Ephemeral Diffie-Hellman** – parametrii DH sunt generați aleator și semnați cu RSA/DSA.

- **Anonymous Diffie-Hellman** – parametrii DH sunt generați aleator fără autentificare.
- **Fortezza** – metodă proprietară.

4. Generarea Cheilor Criptografice

- **Master secret** derivat din pre-master secret folosind MD5 și SHA.
- **Key block** generat din master secret pentru a obține cheile de criptare și autentificare.

5. SSL Record Protocol

- Aplică **fragmentare, compresie, autentificare (MAC) și criptare**.
- **HMAC** folosit pentru autentificare (MD5, SHA-1).

6. Criptarea Datelor

- **Cifruri block:** RC2, DES, 3DES, IDEA, Fortezza.
- **Cifruri șir:** RC4.

7. Protocolul TLS (Transport Layer Security)

- Standardizare SSL de către IETF (RFC 2246).
- **Îmbunătățiri față de SSL:**
 - Suport pentru **noi algoritmi** (AES, Camellia, SHA-2).
 - Generare de chei îmbunătățită (PRF).
 - Mesaje de alertare adiționale.
 - Format optimizat al mesajelor.

8. Implementare SSL/TLS

- **Certificate digitale** pentru autentificare (server/client).
- **HTTPS** pentru securizarea tranzațiilor web.
- **Biblioteci criptografice:** OpenSSL, BSAFE.

9. Tipuri de Certificate Digitale

- **Domain Validation (DV)** – verifică doar existența domeniului (rapid).
- **Organization Validation (OV)** – verifică și existența organizației (câteva zile).
- **Extended Validation (EV)** – verificări detaliate ale organizației (câteva săptămâni).
- **Certificate Transparency** – audit public al certificatelor (RFC 9162).

10. Porturi SSL Standard

Serviciu	Port	Descriere
HTTPS	443	HTTP peste TLS/SSL

SMTPS 465 SMTP peste TLS/SSL

IMAPS 993 IMAP4 peste TLS/SSL

POP3S 995 POP3 peste TLS/SSL

11. Atacuri împotriva SSL/TLS

- **Renegotiation Attack**
- **RC4 Attacks**
- **BEAST Attack**
- **CRIME Attack**
- **Heartbleed**
- **ChangeCipherSpec Injection**
- **POODLE Attack**
- **Protocol Downgrade Attack**

→ **Recomandare:** Dezactivarea SSL, utilizarea doar a TLS pentru securitate maximă.

4. Protocoale de Securitate la Nivel Aplicație

1. Pretty Good Privacy (PGP)

- **Creat de:** Phil Zimmerman (1991)
- **Scop:** Protejează e-mailurile și fișierele stocate local
- **Caracteristici:**
 - Folosește algoritmi criptografici moderni
 - Cod sursă disponibil gratuit
 - Funcționează pe multiple platforme (Windows, Unix, Mac OS)
 - Este un **standard Internet** (RFC 4880 - OpenPGP)

2. Servicii oferite de PGP

1. **Autentificare**
2. **Confidențialitate**
3. **Compresie date**
4. **Compatibilitate cu e-mailul**

3. Funcționalități importante ale PGP

- **Compresie date:** Se face **înainte de criptare** pentru a reduce dimensiunea fișierelor și a complica analiza criptanalitică. Algoritm folosit: **ZIP/UNZIP**
- **Compatibilitate e-mail:**

- Mesajele criptate sunt **binar**
- Se folosește conversia **Radix 64** pentru a permite transmiterea în sistemele de e-mail
- Aceasta crește dimensiunea mesajului cu **33%**

4. Gestiunea cheilor în PGP

- **Model Web of Trust** (plasa de încredere) – recomandări între utilizatori
- **Inele de chei:**
 - **Public Key Ring** – stochează cheile publice
 - **Private Key Ring** – stochează cheile private
- **Distribuirea cheilor:**
 - Floppy disk
 - E-mail (amprentă de cheie pentru validare)
 - Servere de chei PGP

5. Nivele de încredere în PGP

- **Încrederea în proprietar:** Setată manual de utilizator
 - **Încrederea în semnătură:** Setată automat de sistem
 - **Legitimitatea cheii:** Determinată de suma încrederii în proprietarii care au semnat-o
-

6. Secure / Multipurpose Internet Mail Extensions (S/MIME)

- **Standard RSA Security** pentru securizarea mesajelor MIME
- **Oferă:** Autentificare, confidențialitate, integritate
- **Standardizat prin:** IETF RFC 5751, 5750

7. MIME și limitările sale

- **Probleme ale RFC 822:**
 - Nu poate transmite fișiere binare
 - Nu suportă mesaje de dimensiuni mari
 - Probleme de compatibilitate cu gateway-uri
- **MIME rezolvă aceste probleme prin:**
 - Definirea unor **formate de conținut standardizate** (ex. pentru multimedia)
 - Reguli de **codificare a datelor** pentru a preveni modificarea mesajelor

8. Tipuri de mesaje securizate în S/MIME

- **Enveloped data:** Mesaj criptat
- **Signed data:** Semnătură digitală + mesaj codificat Base64
- **Clear-signed data:** Semnătură digitală vizibilă, mesajul poate fi citit de clienți incompatibili

- **Signed and enveloped data:** Mesaj criptat + semnătură digitală

9. Algoritmi folosiți în S/MIME

- **Funcții hash:**
 - **Obligatoriu:** SHA-1
 - **Opțional:** MD5
- **Semnături digitale:**
 - **Obligatoriu:** DSS
 - **Opțional:** RSA
- **Criptarea datelor:**
 - **Transmițător:** 3DES, RC2/40
 - **Receptor:** Obligatoriu 3DES, opțional RC2/40

10. Vulnerabilități și atacuri asupra PGP și S/MIME

- **EFAIL (mai 2018):** Permite **exfiltrarea conținutului mesajelor criptate**
 - a. Atacuri: **Direct Exfiltration Attack, CBC/CFB Gadget Attack**
 - b. **Soluții:**
 - i. Verificare strictă a integrității mesajelor criptate
 - ii. Dezactivarea afișării resurselor externe în mod implicit
 - iii. Modificarea modului de afișare a mesajelor HTML

5. Standarde de Securitate

1. Rolul și Tipurile de Standarde

- **Rol:** Asigurarea interoperabilității între sisteme.
 - **Tipuri:**
 - **De jure** – Stabilite oficial (ex: FIPS, ANSI).
 - **De facto** – Adoptate pe scară largă (ex: PKCS).
-

2. Organizații de Standardizare

- **Internaționale:**
 - **Internet Society** (IETF, IAB, IESG) – creează RFC-uri.
 - **ITU** (Radiocomunicații, Telecomunicații, Dezvoltare).
 - **IEEE** – standarde pentru criptografie și rețele.
 - **ISO** – standarde pentru securitate și criptografie.
- **Naționale:**
 - **ANSI (SUA), BSI (UK), AFNOR (FR), DIN (DE).**

- **NIST (SUA)** – FIPS (ex: AES, HMAC, DSS).
 - **Alte organizații relevante:**
 - **RSA Labs** – PKCS (standarde criptografice cheie).
 - **W3C** – Standardizare XML pentru securitate.
 - **The OpenGroup** – CDSA (Common Data Security Architecture).
 - **OASIS** – SAML (Security Assertion Markup Language).
 - **PC/SC Workgroup** – standarde pentru smart cards.
 - **EMV (Europay, Mastercard, VISA)** – standarde bancare.
-

3. Standardele Majore pe Securitate și Criptografie

IETF (Security Working Groups)

- Include grupuri pentru autentificare (OAuth), TLS, IPsec, securitate automată, protecție împotriva DDoS.

ITU

- Standardele **X.509** (framework pentru autentificare), **X.800** (arhitectura securității OSI), **X.736** (raportare alarme de securitate).

IEEE

- **IEEE P1363** – Specificații pentru criptografie cu chei publice.
- **IEEE 802.1x** – Control de acces la rețea.
- **IEEE 802.11i** – Securitate în rețele wireless.

EESSI (European Electronic Signature Standardization Initiative)

- Standarde pentru **semnătura electronică** (XAdES, timestamping, cerințe pentru autorități de certificare).

ISO

- **ISO 27000** – Managementul securității informației.
- **ISO 7498-2** – Modelul OSI de securitate.
- **ISO 9797** – MAC (Message Authentication Codes).
- **ISO 11770** – Managementul cheilor criptografice.
- **ISO 13888** – Non-repudiare.
- **ISO 14888** – Semnături digitale.

ANSI (American National Standards Institute)

- **ANSI X9.23** – DES.
- **ANSI X9.30** – Standard de semnătură digitală.

- **ANSI X9.42** – Acord de chei Diffie-Hellman.
- **ANSI X9.62** – Algoritmul ECDSA.

NIST (National Institute of Standards and Technology)

- **FIPS 46-2** – DES.
- **FIPS 197** – AES.
- **FIPS 186** – DSS.
- **FIPS 198** – HMAC.

RSA Laboratories

- **PKCS #1** – Standard RSA.
- **PKCS #3** – Diffie-Hellman.
- **PKCS #5** – Criptografie bazată pe parole.
- **PKCS #7** – Mesaje criptografice.
- **PKCS #11** – Interfață pentru tokenuri criptografice.
- **PKCS #15** – Format de informații pentru tokenuri criptografice.

4. Concluzie

Există o varietate de standarde și organizații implicate în securitatea informației, fiecare având un rol specific. Cele mai importante standarde sunt cele stabilite de **ISO, NIST, ANSI, IEEE, IETF, ITU și RSA Labs**. În practică, acestea sunt utilizate pentru **gestionarea cheilor, criptare, autentificare, protecția comunicațiilor și securitatea sistemelor**.

1. Protocoale de Autentificare.....	1
1. Authentication, Authorization, Accounting (AAA).....	1
2. Factori de autentificare.....	1
3. Tipuri de autentificare.....	1
4. Protocoale de autentificare.....	1
5. Kerberos – Funcționare și securitate.....	1
6. Autentificare cu certificate digitale.....	1
7. Generatoare de parole de unică folosință (OTP).....	2
8. Metode biometrice.....	2
9. Evaluarea metodelor de autentificare.....	2
2. Protocoale de Securitate la Nivel Rețea.....	2
1. Rețele Private Virtuale (VPN).....	2
2. Tehnologii de Tunelare a Datelor.....	2
3. VPN Remote Access & Site-to-Site.....	3
4. Avantajele VPN.....	3
IPSec (Internet Protocol Security).....	3
5. Arhitectura IPSec.....	3
6. Protocoale IPSec: AH și ESP.....	3
7. Security Association (SA).....	3
8. Internet Key Exchange (IKE).....	4
9. Moduri de lucru IKE.....	4
Perfect Forward Secrecy (PFS).....	4
10. Implementarea IPSec VPN.....	4
11. Soluții IPSec VPN.....	4
3. Protocoale de Securitate la Nivel Transport.....	5
1. Protocolul SSL (Secure Sockets Layer).....	5
2. Protocoale SSL.....	5
3. SSL Handshake Protocol (Negocierea Conexiunii).....	5
4. Generarea Cheilor Criptografice.....	6
5. SSL Record Protocol.....	6
6. Criptarea Datelor.....	6
7. Protocolul TLS (Transport Layer Security).....	6
8. Implementare SSL/TLS.....	6
9. Tipuri de Certificate Digitale.....	6
10. Porturi SSL Standard.....	6
11. Atacuri împotriva SSL/TLS.....	7
4. Protocoale de Securitate la Nivel Aplicație.....	7
1. Pretty Good Privacy (PGP).....	7
2. Servicii oferite de PGP.....	7
3. Funcționalități importante ale PGP.....	7
4. Gestiunea cheilor în PGP.....	8

5. Nivele de încredere în PGP.....	8
6. Secure / Multipurpose Internet Mail Extensions (S/MIME).....	8
7. MIME și limitările sale.....	8
8. Tipuri de mesaje securizate în S/MIME.....	8
9. Algoritmi folosiți în S/MIME.....	9
10. Vulnerabilități și atacuri asupra PGP și S/MIME.....	9
5. Standarde de Securitate.....	9
1. Rolul și Tipurile de Standarde.....	9
2. Organizații de Standardizare.....	9
3. Standardele Majore pe Securitate și Criptografie.....	10
IETF (Security Working Groups).....	10
ITU.....	10
IEEE.....	10
EESSI (European Electronic Signature Standardization Initiative).....	10
ISO.....	10
ANSI (American National Standards Institute).....	10
NIST (National Institute of Standards and Technology).....	11
RSA Laboratories.....	11
4. Concluzie.....	11